International Journal of Information Security (2026) 25:177
https://doi.org/10.1007/s10207-026-01347-6

REGULAR CONTRIBUTION

Prioritizing selected ISO/IEC 27001 implementation investment items using multi-criteria decision analysis

Sadrettin Çodur[1] · Fatih Tiryaki[2]

Received: 21 January 2026 / Accepted: 10 October 2026
© The Author(s) 2026

Abstract

This study proposes an expert-based multi-criteria decision analysis framework for prioritizing selected ISO/IEC 27001 implementation investment items. The framework evaluates eleven practical implementation items, including ten major investment areas and the Statement of Applicability, which are relevant to early-stage ISO/IEC 27001 implementation planning. Judgments obtained from ten information security and IT professionals were first aggregated using RANCOM, a ranking-based subjective weighting method that allows ties and accommodates expert hesitation. The resulting priority structure was then compared with Copeland and PageRank rankings, and its stability was examined through a leave-one-expert-out sensitivity analysis. The findings indicate strong convergence across methods for the upper-priority items, with C1 (Server Room Setup), C3 (System Redundancy/Backup), and C2 (Disaster Recovery Center) consistently emerging as the highest-priority implementation investments. Smaller numerical differences among mid- and lower-ranked items indicate that these results should be interpreted with attention to numerical proximity and organizational context. Overall, the study provides a practical decision-support framework for early-stage ISO/IEC 27001 implementation planning.

Keywords ISO/IEC 27001 · Information security management system · Multi-criteria decision analysis · RANCOM · Copeland · PageRank · Expert judgment · Implementation planning · Investment prioritization · Decision support

1 Introduction

With the accelerating digitalization of the global economy, information security has become a strategic priority for organizations. As dependence on digital systems increases, the attack surface available to malicious actors expands accordingly [1]. Cybercrime modalities—such as hacking and supply-chain attacks—have therefore evolved into progressively more severe threats for institutions and industries [2]. In this context, many organizations adopt the ISO/IEC 27001 standard as a foundational framework for establishing a robust Information Security Management System (ISMS) [3].

ISO/IEC 27001 stands out as a leading framework for ISMS implementation by embracing a holistic management perspective. It requires organizations to identify information security risks and to select appropriate controls to mitigate those risks within the broader context of organizational business risks. Furthermore, the standard is grounded in continual improvement, ensuring that security is treated not as a static state but as a dynamic process that adapts to emerging threats [4].

Although the strategic value of ISO/IEC 27001 is widely recognized, its practical implementation presents substantial challenges. The standard is comprehensive, and the resources required to achieve full conformity are considerable [5]. This reality constitutes a material barrier for organizations. The decision problem addressed in this study is: when organizations initiate ISO/IEC 27001 implementation under resource constraints, which selected implementation investment items should receive earlier managerial attention?

✉ Sadrettin Çodur
sadrettincodur@ktu.edu.tr

Fatih Tiryaki
fatihtiryaki@ktu.edu.tr

[1] Department of Property Protection and Security, Araklı Ali Cevat Özyurt Vocational School, Karadeniz Technical University, Trabzon, Turkey

[2] Department of Electronics and Automation, Araklı Ali Cevat Özyurt Vocational School, Karadeniz Technical University, Trabzon, Turkey

Published online: 18 October 2026

In this study, eleven practical implementation investment items are considered. These items include ten major investment areas frequently encountered during ISO/IEC 27001 implementation, together with the Statement of Applicability (SoA), which is a mandatory documentation component of the standard. The initial set of items was determined by considering ISO/IEC 27001 implementation requirements, common practice-oriented investment needs, and the opinions of information security and IT professionals. Accordingly, the selected items are treated as a focused set of implementation-related investment items that are relevant for organizations planning the early stages of ISO/IEC 27001 implementation, rather than as a direct prioritization of the entire ISO/IEC 27001 control set.

Prioritizing these selected ISO/IEC 27001 implementation investment items is inherently a multi-dimensional decision-making problem. It requires the evaluation of multiple alternatives and the aggregation of expert judgments. However, expert-driven decision processes may also involve subjectivity, hesitation, and uncertainty. Multi-Criteria Decision Analysis (MCDA) methods offer a structured response to this challenge by transforming expert judgments into transparent and comparable priority scores. In this way, decision-making can be supported by a systematic analytical framework rather than relying solely on intuition or informal managerial judgment [6].

This study uses the RANCOM ranking method as the primary mechanism for aggregating expert judgments. RANCOM is a subjective weighting method designed to process ordinal expert rankings while allowing ties and reducing cognitive burden [7–9]. The priority structure obtained from RANCOM is then compared with those produced by Copeland and PageRank. Copeland and PageRank are used as independent comparative ranking approaches to examine whether the main prioritization results remain stable under different aggregation logics [10–13].

The contribution of this study lies in offering a focused, expert-based, and comparative decision-support perspective for early-stage ISO/IEC 27001 implementation planning. Rather than proposing a complete resource allocation optimization model, the study operationalizes selected implementation investment items as managerial decision units, aggregates expert rankings through RANCOM, and compares the resulting priority structure with dominance-based and network-based ranking approaches. This comparative perspective helps decision-makers interpret which implementation items consistently emerge as upper-priority areas and which items require more context-sensitive consideration.

The remainder of the paper is organized as follows. Section 2 reviews the literature on ISO/IEC 27001 implementation challenges, MCDA applications in information security, and cybersecurity investment decision support. Section 3 presents the methodological framework, including criteria definition, expert judgment collection, RANCOM, Copeland, PageRank, and the leave-one-expert-out sensitivity analysis. Section 4 reports the implementation results and comparative rankings. Section 5 presents the main findings. Finally, Sect. 6 concludes the paper by discussing practical implications, limitations, and future research directions.

2 Literature review

ISO/IEC 27001 is among the most widely used and internationally accepted standards for information security. On 25 October 2022, the third edition of the standard, ISO/IEC 27001:2022, was published with the aim of addressing global cybersecurity challenges and strengthening digital trust. The original 2005 version largely emphasized traditional IT security. The 2013 revision introduced a higher-level structure (Annex SL) to enhance alignment with other management standards such as ISO 9001. The 2022 revision reorganized the Annex A control structure and introduced updated control themes reflecting contemporary concerns such as cloud services, threat intelligence, data leakage prevention, and monitoring activities [14–17]. Since the 2022 revision reorganized Annex A controls, this study treats the selected items as ISO/IEC 27001 implementation investment items rather than as a direct one-to-one prioritization of all Annex A controls.

Although the strategic value of ISO/IEC 27001 is widely recognized, its implementation entails substantial obstacles. The standard is extensive, and the resources required for full compliance are significant. This becomes a practical implementation barrier for SMEs, which constitute the backbone of many economies yet frequently lack dedicated security budgets or specialized personnel. Under these constraints, a staged approach is often required, and the Chief Information Security Officer (CISO) must decide which investment should be addressed first [18, 19].

This decision is inherently risky. Over-investing in certain logical controls, such as expensive Network Access Control (NAC) software, while neglecting physical and environmental foundations such as a secure server room can yield a fragile security posture in which a simple physical intrusion or power failure renders advanced cyber defenses ineffective. Conversely, focusing on bureaucratic compliance—such as drafting only the SoA without implementing substantive controls—may result in "security on paper," i.e., a system that passes superficial document inspection yet fails operationally.

The strategic nature of information security management and pervasive resource constraints have pushed researchers

beyond qualitative "best practice" guidance toward quantitative and mathematical decision-support models. Accordingly, this section reviews MCDA approaches applied within ISO/IEC 27001 and related security frameworks, identifies methodological clusters in the literature, and analyzes the structural gaps that the present study seeks to address.

2.1 MCDA in information security contexts

A review of the literature indicates that MCDA methods have become a standard tool for evaluating information security risks and selecting controls. In their systematic review of information security risk analysis, Maček et al. (2020) report that the Analytic Hierarchy Process (AHP) and its derivatives dominate the field due to their ability to hierarchically decompose complex decision problems [6].

This trend has intensified in recent studies. For instance, Nikbakht et al. (2025) integrated AHP and TOPSIS to determine the relative importance of security controls within the COBIT 2019 framework, thereby ranking which controls should be prioritized in governance processes [20]. Similarly, Daghouri and Mansouri (2024) proposed a hierarchical model based on AHP to compare information security metrics across five sectors—such as healthcare, finance, and education—and to measure cross-sector security maturity [21]. While these studies contribute valuable insights into the weighting of security controls, they often treat controls as independent variables.

2.2 Uncertainty management and fuzzy approaches

To mitigate subjective uncertainty and human error in expert judgments, recent research increasingly shifts toward fuzzy logic-based hybrid models. Khan et al. (2025) developed a Fuzzy-AHP-based framework to optimize software maintenance and deployment in information security systems and argued that it produces more consistent outcomes than classical methods in uncertain decision environments [22]. Barlybayev and Turginbayeva (2025) proposed an advanced fuzzy expert system capable of processing linguistic variables for information security risk assessment [23]. In the context of risk evaluation, Tariq et al. (2020) adopted a similar Fuzzy-AHP approach to prioritize controls in dynamic environments such as cloud computing and wireless sensor networks (WSN) [24].

Moreover, Turskis et al. (2019) employed a hybrid MCDA approach that integrates the Delphi method, a fuzzified Eckenrode method, AHP, Likert-type fuzzy scales, and fuzzy set theory to assess information security risks in critical information infrastructures [25]. Nasser et al. (2018) similarly used Fuzzy AHP under uncertainty to measure organizational security maturity [26].

2.3 Factor analyses and cause–effect relationships

Some researchers have relied on methods such as DEMATEL (Decision Making Trial and Evaluation Laboratory) to model interactions among criteria. Muntaha et al. (2019) used DEMATEL to analyze factors hindering ISO/IEC 27001 implementation and mapped causal relationships among these factors [27]. In a related vein, Ramalingam et al. (2018) combined DEMATEL with the Figure of Merit (FoM) technique to optimize IT governance (IT-GRC) controls [28]. Such approaches are particularly valuable because security controls and implementation investments are rarely independent in practice. Nevertheless, the present study does not model causal dependencies among investment items; instead, it uses comparative ranking methods to examine whether expert-based prioritization remains stable across different aggregation logics.

2.4 Cybersecurity investment decision support

Cybersecurity investment has also been examined from broader decision-support, economic, and game-theoretic perspectives. Fielder et al. (2016) reviewed decision-support approaches for cybersecurity investment and emphasized that organizations must balance security improvement with limited financial and operational resources [29]. Zhang and Malacaria (2021) developed a Bayesian Stackelberg game model for cybersecurity decision support, highlighting the strategic interaction between attackers and defenders in investment decisions [30]. In a later study, Zhang and Malacaria (2023) further discussed cybersecurity spending beyond the logic of a single optimal investment level, showing that security investment decisions are dynamic and context dependent [31].

These studies provide important theoretical and analytical foundations for cybersecurity investment decision-making by examining issues such as optimal spending, attacker–defender interaction, and broader cybersecurity investment strategy. The present study differs from this stream by focusing specifically on the early-stage prioritization of selected ISO/IEC 27001 implementation investment items. In this respect, it complements the existing cybersecurity investment literature by offering an expert-based comparative ranking perspective for ISO/IEC 27001 implementation planning.

2.5 Research gap and study positioning

Although the literature contains multiple applications of MCDA in information security, these studies often focus on abstract "success factors," implementation barriers, control selection, risk treatment alternatives, or maturity assessment. For example, Barraza de la Paz et al. (2023) examined ISO/IEC 27001 technical control 8.1 through Fault Tree

Analysis (FTA) and MCDA, thereby providing a more technical control-oriented perspective [32]. Similarly, broader cybersecurity investment studies provide valuable decision-support and economic models, but they generally address optimal spending, attacker–defender interaction, or broad investment strategy rather than the comparative ranking of practical ISO/IEC 27001 implementation items based on expert judgments.

Within this context, the present study contributes to the literature by focusing on a practical prioritization problem that arises during the early stages of ISO/IEC 27001 implementation. Specifically, it examines how selected implementation investment items can be prioritized through expert judgments and comparative ranking methods. By combining RANCOM-based expert aggregation with Copeland and PageRank comparisons, the study offers a structured way to examine whether the resulting priority structure remains consistent across different ranking logics. This comparative perspective provides decision-makers with additional evidence when interpreting expert-driven prioritization results.

The study also extends prior MCDA applications in information security by shifting attention from general control selection, maturity assessment, and implementation barriers toward selected ISO/IEC 27001 implementation investment items. Moreover, the framework highlights the practical value of interpreting close scores cautiously, particularly in mid- and lower-priority items where expert judgments may be more context-dependent. Therefore, the study contributes to ISO/IEC 27001 implementation planning by offering a transparent, expert-based, and comparative prioritization approach that can support early-stage managerial decision-making.

3 Methodology

3.1 The RANCOM method

The RANCOM method, developed by Więckowski et al., addresses the problem of expert hesitation and inconsistency in subjective weighting problems. In many decision-making contexts, experts may find it difficult to provide precise ratio-scale judgments, such as stating that one criterion is exactly two or three times more important than another. By contrast, providing an ordinal ranking, such as indicating that one criterion is more important than another, is cognitively easier and more consistent with how experts often express practical preferences [7, 8].

RANCOM constructs a Matrix of Ranking Comparison (MAC) based on ordinal expert inputs. By translating ranking positions into a comparison matrix whose entries take values of 1, 0.5, or 0, the method represents ordinal preference relations rather than cardinal preference intensity. In this study, RANCOM is used as the primary expert-judgment aggregation method because it allows tied rankings and reduces the cognitive burden placed on experts [7–9]. In this context, the allowance of tied rankings reflects hesitation at the ordinal preference level rather than a complete quantification of expert uncertainty. Expert-specific confidence, experience, and judgment variability are not explicitly parameterized in the present RANCOM application.

The method steps are as follows.

Step 1. Define the criteria ranking: The expert ranks criteria by importance. In this process, a lower numerical value indicates higher importance (e.g., rank 1 is the most important criterion). Criteria with equal importance may be assigned the same rank number (ties allowed) [7–9].

Step 2. Establish the matrix of ranking comparison (MAC): Based on the expert ranking, an $n \times n$ comparison matrix (MAC) is constructed. By comparing criteria positions in the ranking (f(C)), matrix elements (a_{ij}) are determined [7–9, 33].

When the standard "three-value" function is used, the comparison is as in Eq. (1) [9, 33]:

$$a_{ij} = \begin{cases} 1 & If\ f(C_i) < f(C_j) \\ 0.5 & If\ f(C_i) = f(C_j) \\ 0 & If\ f(C_i) > f(C_j) \end{cases} \tag{1}$$

In this formulation, the values 1, 0.5, and 0 represent ordinal preference relations rather than cardinal importance intensities. Specifically, 1 indicates that criterion C_i is preferred to criterion C_j, 0.5 indicates equality or a tie, and 0 indicates that C_i is less preferred than criterion C_j. Thus, the comparison matrix reflects the relative ordering of criteria while preserving the ranking-based structure of RANCOM.

Step 3. Calculate the summed criteria weights (SCW): Each row of the MAC matrix is summed to obtain the Summed Criteria Weights (SCW) vector, as shown in Eq. (2) [9, 33]:

$$SCW_i = \sum_{j=1}^{n} a_{ij} \tag{2}$$

Step 4. Calculate the normalized RANCOM weights: Finally, each criterion weight (w_i) is normalized by dividing its SCW value by the sum of all SCW values, as in Eq. (3) [9, 33]:

$$w_i = \frac{SCW_i}{\sum_{i=1}^{n} SCW_i} \tag{3}$$

In the RANCOM calculation, the diagonal elements of the MAC matrix were retained as $a_{ii} = 0.5$, representing equality of a criterion with itself.

3.2 Research framework and criteria definition

The research framework evaluates eleven ISO/IEC 27001 implementation investment items (C1–C11) that are relevant to early-stage ISO/IEC 27001 implementation planning. These items were determined by considering ISO/IEC 27001 implementation requirements, practice-oriented investment needs, and the opinions of information security and IT professionals. The selected items cover physical infrastructure, continuity and recovery, access control, documentation, awareness, hosting architecture, network security, identity management, and competency development.

The study is framed within the ISO/IEC 27001:2022 implementation context. Accordingly, the items are defined as practical implementation investment items associated with ISO/IEC 27001 implementation and ISMS improvement activities. They are grouped as managerial decision units because organizations often need to decide the order in which such investments should be addressed during implementation planning. Some items may be operationally related in practice; for example, server room setup and supporting infrastructure services are often planned together. However, they are evaluated separately because they involve different technical activities, cost components, procurement processes, and operational responsibilities.

The eleven implementation investment items are defined as follows:

- *C1 (Server Room Setup)*: Construction of a dedicated, physically secure environment to host IT assets, including racks, cabling arrangements, physical layout, and controlled access infrastructure. This item supports the physical security dimension of ISO/IEC 27001 implementation.
- *C2 (Disaster Recovery Center, DRC)*: Establishment of an off-site or alternative recovery capability, such as a hot, warm, or cold site, to support business continuity in the event of a major disruption at the primary facility. This item addresses the availability and resilience dimensions of ISMS implementation.
- *C3 (System Redundancy/Backup)*: Implementation of high-availability structures, failover mechanisms, and backup procedures such as full, incremental, or differential backups. This item supports data recoverability, service continuity, and the availability dimension of information security.
- *C4 (Card Access System)*: Deployment of electronic access control mechanisms for sensitive areas, including electronic locks, proximity cards, access logs, and authorization management. This item provides accountability for physical access to information processing areas.
- *C5 (Infrastructure Maintenance)*: Installation and maintenance of supporting environmental and utility services such as uninterruptible power supplies (UPS), fire suppression systems, precision cooling, and environmental monitoring. Although closely related to C1, this item is evaluated separately because it involves different technical activities, cost components, procurement processes, and operational responsibilities.
- *C6 (SoA Documentation)*: Drafting and approval of the SoA, which documents the applicability status and justification of controls considered within the ISMS. The SoA provides a central link between risk treatment decisions and selected controls.
- *C7 (Awareness Training)*: Delivery of general information security awareness activities for employees, including policy awareness, phishing awareness, incident reporting behavior, and secure use of organizational systems. This item supports the development of security-aware behavior across the organization.
- *C8 (Email Hosting Architecture and Cloud-Service Governance)*: Determination and governance of the organization's email hosting architecture, including on-premises, cloud-based, or hybrid service models. This item is associated with secure communication, service governance, and cloud-service security considerations.
- *C9 (NAC System Setup)*: Deployment of Network Access Control (NAC) mechanisms, such as 802.1X-based authentication and device compliance checks, to regulate network access by users and endpoints. This item supports network security, access control, and endpoint governance.
- *C10 (Domain Structure Migration)*: Implementation of a centralized directory service or identity management environment, such as Active Directory or an equivalent system, to manage authentication, authorization, and policy enforcement. This item supports centralized access management.
- *C11 (Competency Training)*: Specialized technical training and certification-oriented professional development for the IT security team, including security administration, incident response, audit readiness, and relevant certifications. This item differs from C7 because it targets technical and managerial competence rather than general employee awareness.

3.3 Expert panel and data collection

The prioritization process was based on the judgments of ten information security and IT professionals. The experts were selected according to their professional involvement in information security management, system and network administration, cybersecurity, ISO/IEC 27001-related activities, IT governance, software development, certification processes, and institutional IT infrastructure management.

The purpose of the expert panel was to obtain practical judgments from professionals who are familiar with the managerial and technical challenges of ISO/IEC 27001 implementation.

Each expert was asked to evaluate the eleven selected ISO/IEC 27001 implementation investment items according to their perceived priority for early-stage ISO/IEC 27001 implementation planning. Tied rankings were permitted so that experts could express equal priority levels where two or more items were considered similarly important. This approach was preferred to reduce forced-choice bias and to better reflect expert hesitation in subjective prioritization. The rankings obtained from the experts were then transformed into Matrix of Ranking Comparison (MAC) structures according to the RANCOM procedure.

To ensure transparency while preserving confidentiality, the experts were anonymized as E1–E10. Appendix A, Table A1, summarizes the professional background of the expert panel in terms of professional role, main expertise, ISO/IEC 27001 or information security experience, and education level. The expert identities were not disclosed because the analysis focuses on aggregated expert judgment rather than individual-level professional evaluation. The experts did not evaluate an organization-specific procurement decision, and no direct financial conflict of interest was reported.

3.4 Comparative ranking procedures: Copeland and Pagerank

To examine the consistency of the expert-based priority structure across different ranking logics, the RANCOM results were compared with Copeland and PageRank rankings. These methods were selected because they represent different approaches to ranking. RANCOM aggregates ordinal expert judgments into normalized subjective weights. Copeland evaluates alternatives through pairwise dominance logic. PageRank represents the preference structure as a directed network and estimates the relative importance of items through iterative importance propagation.

For Copeland and PageRank, the same off-diagonal expert preference information was used. Since self-comparisons do not contribute to pairwise dominance or network-based importance propagation, diagonal elements were set to zero in these two comparative procedures.

3.4.1 Copeland ranking

The Copeland method evaluates each item according to its pairwise wins and losses against the other items. In this study, the preference information obtained from the experts was first transformed into an aggregated pairwise dominance matrix. For each item pair, item C_i was considered to have a pairwise win over item C_j if the dominance value of C_i over C_j was greater than the corresponding dominance value of C_j over C_i. Conversely, item C_i was considered to have a pairwise loss if this dominance value was lower. Equal dominance values were treated as neutral pairwise relations [10, 11].

The Copeland score for each item was calculated using Eq. (4) [10, 11]:

$$CS_i = W_i - L_i \tag{4}$$

where W_i represents the number of pairwise wins and L_i represents the number of pairwise losses for item C_i. Higher Copeland scores indicate stronger pairwise dominance within the aggregated expert preference structure [10, 11].

3.4.2 PageRank ranking

PageRank was used to evaluate the network-based importance of the implementation investment items. In this procedure, each item was represented as a node in a directed preference network. A directed edge was assigned from the less-preferred item to the more-preferred item so that importance flowed toward items that were more frequently preferred by experts. Tied items were treated as equal relations and did not create a directional dominance advantage [12, 13].

The PageRank algorithm was implemented using a damping factor of $d = 0.85$. Iterations were continued until the change in PageRank scores between successive iterations was below 10^{-8}, or until a maximum of 1000 iterations was reached. The resulting PageRank scores were normalized so that their total equaled 1. The final PageRank weights were obtained by averaging the PageRank vectors calculated from the individual expert preference matrices [12, 13].

3.5 Leave-one-expert-out sensitivity analysis

A leave-one-expert-out sensitivity analysis was conducted to examine the stability of the expert-based prioritization results. In this procedure, one expert was excluded at a time, and the average RANCOM weights were recalculated using the remaining nine experts. This process was repeated for each expert.

The ranking obtained from each exclusion scenario was compared with the baseline ranking calculated from all ten experts. Spearman rank correlation coefficients were used to measure the similarity between each leave-one-expert-out ranking and the full-expert reference ranking. Higher Spearman correlation values indicate that the overall priority structure remains stable despite the exclusion of an individual expert.

The leave-one-expert-out procedure provides an assessment of ranking robustness with respect to changes in expert

Table 1 MAC matrix obtained from Expert 1's ranking

	C1	C3	C2	C11	C5	C8	C7	C9	C10	C4	C6
C1	0.5	1	1	1	1	1	1	1	1	1	1
C3	0	0.5	1	1	1	1	1	1	1	1	1
C2	0	0	0.5	0.5	1	1	1	1	1	1	1
C11	0	0	0.5	0.5	1	1	1	1	1	1	1
C5	0	0	0	0	0.5	1	1	1	1	1	1
C8	0	0	0	0	0	0.5	1	1	1	1	1
C7	0	0	0	0	0	0	0.5	1	1	1	1
C9	0	0	0	0	0	0	0	0.5	0.5	1	1
C10	0	0	0	0	0	0	0	0.5	0.5	1	1
C4	0	0	0	0	0	0	0	0	0	0.5	1
C6	0	0	0	0	0	0	0	0	0	0	0.5

composition. This analysis captures the effect of excluding individual experts from the panel, while broader sources of uncertainty, such as alternative panel sizes, expert-weighting schemes, and probabilistic preference distributions, remain outside the scope of the present analysis.

4 Implementation and results

In this section, the RANCOM calculation is first illustrated using Expert 1's ranking. The MAC matrices derived from the remaining nine experts are provided in Supporting Information Tables 1–9. The same procedure was applied to all expert rankings, and the baseline priority weights were obtained by averaging the individual expert-level weight vectors. The section then presents the leave-one-expert-out analysis and the comparative ranking results obtained from RANCOM, Copeland, and PageRank.

4.1 Stages of applying the RANCOM method

Step 1. The expert ranks the criteria by importance. According to Expert 1, the ranking is:

C1 > C3 > C2 = C11 > C5 > C8 > C7 > C9 = C10 > C4 > C6.

Step 2. The MAC matrix is constructed from the expert's ranking. In this step, the comparison matrix derived from the expert ranking is provided in Table 1.

Step 3. Calculate the Summed Criteria Weights

Row sums of the MAC matrix are calculated to obtain the SCW vector as in Eq. (2). These results are shown in Table 2.

Step 4. Calculate the normalized RANCOM weights

The normalized RANCOM weights (w_i) for Expert 1 were obtained by dividing each SCW value by the total SCW value, as defined in Eq. (3). The resulting Expert 1 weights are presented in Table 2. The same RANCOM procedure was then applied to the rankings provided by the remaining experts. After calculating the individual weight vector for each expert, the baseline priority weights were obtained by taking the arithmetic mean of the ten expert-level weight vectors. These aggregated baseline weights, together with the leave-one-expert-out recalculated weights, are presented in Table 3.

Table 2 SCW and normalized RANCOM weights obtained from Expert 1's ranking

	SCW	w_i
C1	10.5	0.1736
C3	9.5	0.1570
C2	8	0.1322
C11	8	0.1322
C5	6.5	0.1074
C8	5.5	0.0909
C7	4.5	0.0744
C9	3	0.0496
C10	3	0.0496
C4	1.5	0.0248
C6	0.5	0.0083
Total	60.5	1

4.2 Baseline expert-aggregated priorities and leave-one-expert-out analysis

After calculating the individual RANCOM weight vector for each expert, the baseline priority weights were obtained by taking the arithmetic mean of the ten expert-level weight vectors. The first row of Table 3 presents the aggregated baseline weights. To examine the stability of the priority structure, a

Table 3 Results of leave-one-expert-out (LOO) sensitivity analysis based on expert exclusion

Scenario	C1	C2	C3	C4	C5	C6	C7	C8	C9	C10	C11
All Experts (Avg)	0.1669	0.1372	0.1554	0.0851	0.1149	0.0413	0.0455	0.0661	0.0620	0.0628	0.0628
LOO (Expert 1)	0.1662	0.1377	0.1552	0.0918	0.1157	0.0450	0.0422	0.0634	0.0634	0.0643	0.0551
LOO (Expert 2)	0.1662	0.1442	0.1552	0.0900	0.1120	0.0450	0.0478	0.0597	0.0624	0.0579	0.0597
LOO (Expert 3)	0.1699	0.1350	0.1534	0.0826	0.1139	0.0432	0.0459	0.0670	0.0606	0.0597	0.0689
LOO (Expert 4)	0.1680	0.1368	0.1534	0.0900	0.1139	0.0358	0.0478	0.0670	0.0680	0.0615	0.0579
LOO (Expert 5)	0.1662	0.1359	0.1561	0.0808	0.1157	0.0432	0.0496	0.0661	0.0588	0.0624	0.0652
LOO (Expert 6)	0.1662	0.1368	0.1552	0.0845	0.1157	0.0441	0.0441	0.0597	0.0643	0.0680	0.0615
LOO (Expert 7)	0.1662	0.1350	0.1570	0.0808	0.1157	0.0358	0.0422	0.0680	0.0634	0.0670	0.0689
LOO (Expert 8)	0.1680	0.1350	0.1552	0.0817	0.1148	0.0404	0.0450	0.0707	0.0588	0.0615	0.0689
LOO (Expert 9)	0.1662	0.1377	0.1579	0.0771	0.1157	0.0358	0.0441	0.0725	0.0606	0.0652	0.0670
LOO (Expert 10)	0.1662	0.1377	0.1552	0.0918	0.1157	0.0450	0.0459	0.0670	0.0597	0.0606	0.0551

leave-one-expert-out sensitivity analysis was conducted. In this procedure, one expert was excluded at a time, and the average weights were recalculated using the remaining nine experts. The resulting rankings were then compared with the baseline ranking obtained from all ten experts.

Table 3 presents the baseline weights and the recalculated weights obtained under each leave-one-expert-out scenario. The results show that the upper-priority items remain stable across the expert-exclusion scenarios. In particular, C1 (Server Room Setup), C3 (System Redundancy/Backup), and C2 (Disaster Recovery Center) consistently remain within the highest-priority group. This indicates a strong convergence among experts regarding the importance of foundational infrastructure, redundancy/backup, and disaster recovery capabilities during early-stage ISO/IEC 27001 implementation planning.

Figure 1 illustrates the rank changes of the eleven implementation investment items under the leave-one-expert-out scenarios. Compared with the upper-priority items, several mid- and lower-ranked items show more visible rank fluctuations. This is particularly relevant for items with close weight values, such as C8 (Email Hosting Architecture and Cloud-Service Governance), C10 (Domain Structure Migration), C11 (Competency Training), C9 (NAC System Setup), C7 (Awareness Training), and C6 (SoA Documentation). In such cases, small changes in expert composition may affect the relative ordering of closely weighted items. Therefore, the ranking of mid- and lower-priority items should be interpreted together with their weight differences and organizational context, rather than solely by ordinal position.

Spearman rank correlation coefficients were calculated to measure the similarity between each leave-one-expert-out ranking and the baseline ranking obtained from all experts. As shown in Table 4, the correlation coefficients range from 0.9269 to 0.9977, indicating that the overall priority structure remains largely stable across expert-exclusion scenarios. The lowest value was observed when Expert 6 was excluded, suggesting that this expert contributed a comparatively distinct preference pattern. Nevertheless, the upper-priority structure remained consistent throughout the sensitivity analysis.

Overall, the leave-one-expert-out analysis indicates that the main priority structure is not driven by a single expert. At the same time, the observed rank changes among mid- and lower-priority items show that close numerical scores should be interpreted carefully. This supports a more nuanced reading of the results, in which the upper-priority group provides the clearest prioritization signal, while the remaining items may require additional organization-specific consideration. The observed rank changes are concentrated mainly among closely weighted middle- and lower-priority items, whereas the upper-priority group remains comparatively stable across the leave-one-expert-out scenarios. This pattern indicates that the relative ordering of closely positioned items

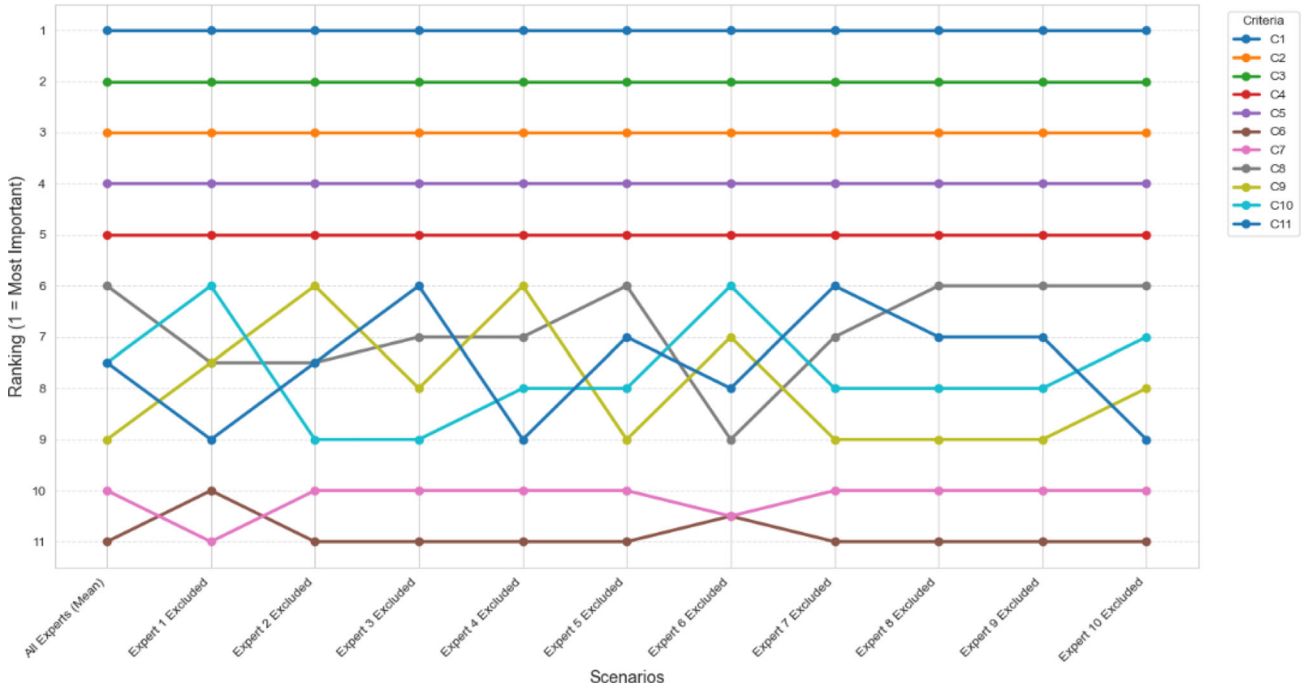


Fig. 1 Sensitivity analysis based on expert exclusion

Table 4 Ranking stability (Spearman correlation with baseline ranking)

Scenario	Correlation
All Experts (Baseline)	1.0000
Expert 1 Excluded	0.9498
Expert 2 Excluded	0.9384
Expert 3 Excluded	0.9704
Expert 4 Excluded	0.9431
Expert 5 Excluded	0.9977
Expert 6 Excluded	0.9269
Expert 7 Excluded	0.9841
Expert 8 Excluded	0.9977
Expert 9 Excluded	0.9977
Expert 10 Excluded	0.9841

is more sensitive to changes in expert composition within the present panel.

4.3 Comparing RANCOM, Pagerank, and Copeland rankings

While RANCOM and PageRank generate normalized weights, Copeland produces dominance-based scores. Therefore, the results are compared primarily in terms of ranking positions rather than direct numerical equivalence. The three methods are used to examine whether the expert-based priority structure remains consistent across different ranking logics. As explained in Sect. 3.4, the same expert-derived preference information was used across the comparative procedures; for Copeland and PageRank, diagonal elements were set to zero because self-comparisons do not contribute to pairwise dominance or network-based importance propagation. Table 5 presents the comparative ranking outputs of RANCOM, Copeland, and PageRank, and Fig. 2 visualizes the rank trajectories across the three methods.

The results indicate a clear convergence in the upper part of the ranking. C1, C3, C2, C5, and C4 retain the same first five positions across all three methods. This pattern shows that the highest-priority structure is highly consistent across different aggregation logics. In practical terms, the experts consistently assign higher priority to server room setup, system redundancy/backup, disaster recovery capacity, infrastructure maintenance, and card access systems in early-stage ISO/IEC 27001 implementation planning.

More variation is observed in the middle and lower parts of the ranking. In RANCOM and Copeland, C8 is positioned sixth, followed by C10 and C11. In PageRank, however, C11 moves to sixth position, while C8 and C10 follow in seventh and eighth positions. This difference may be related to the network-based logic of PageRank, in which an item can gain relative importance through its relational position within the preference network. The close values of C8, C10, C11, and C9 also indicate that their relative order should be interpreted together with their numerical proximity rather than only by ordinal rank.

Table 5 Comparative outputs of RANCOM, Copeland, and PageRank methods

Rank	Criteria	Avg RANCOM weight	Criteria	Avg. Copeland Score	Criteria	Avg. PageRank weight
1	C1	0.1669	C1	9.2	C1	0.2566
2	C3	0.1554	C3	7.8	C3	0.1854
3	C2	0.1372	C2	5.6	C2	0.1328
4	C5	0.1149	C5	2.9	C5	0.0738
5	C4	0.0851	C4	− 0.7	C4	0.0653
6	C8	0.0661	C8	− 3.0	C11	0.0559
7	C10	0.0628	C10	− 3.4	C8	0.0521
8	C11	0.0628	C11	− 3.4	C10	0.0477
9	C9	0.0620	C9	− 3.5	C9	0.0463
10	C7	0.0455	C7	− 5.5	C6	0.0423
11	C6	0.0413	C6	− 6.0	C7	0.0418

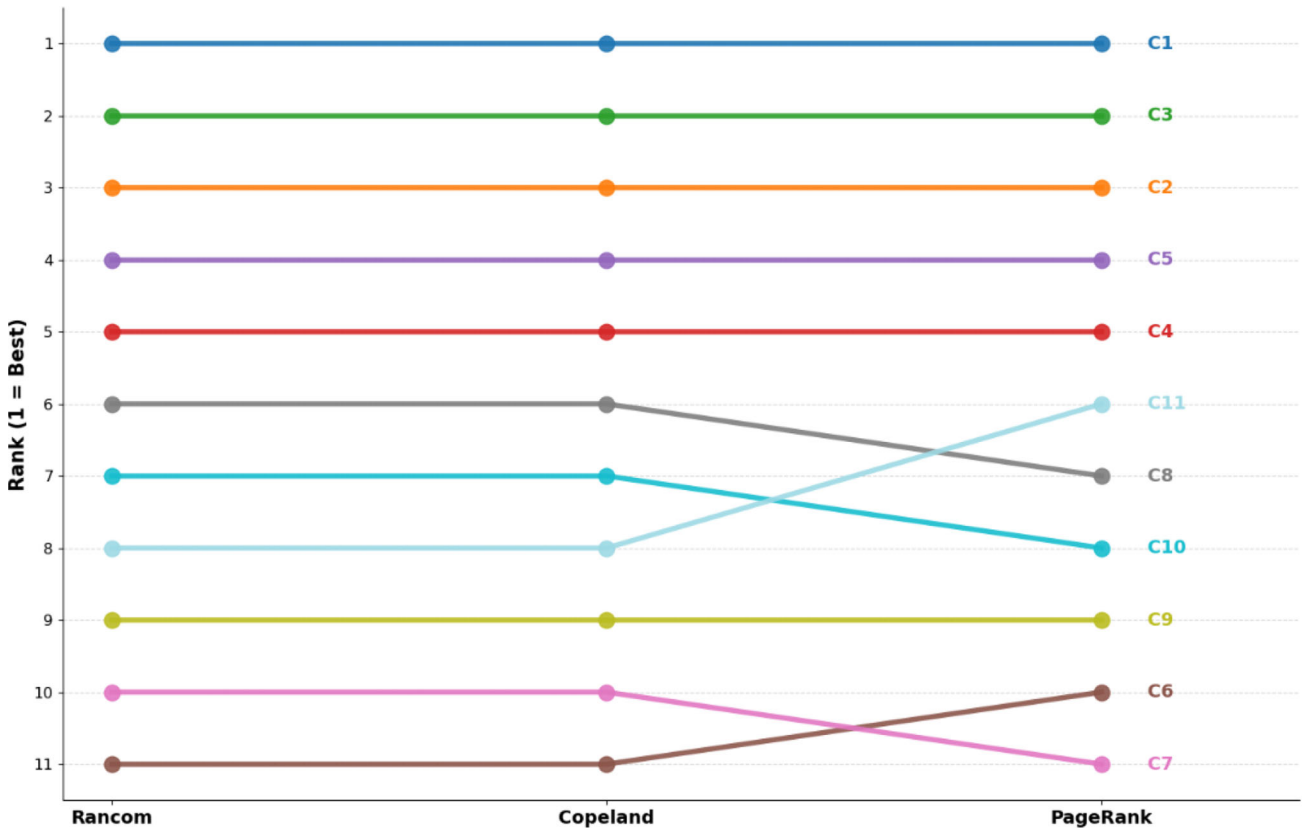


Fig. 2 Rank trajectories of implementation investment items across RANCOM, Copeland, and PageRank

A similar but smaller difference appears at the lower end of the ranking. C6 and C7 occupy the last two positions across the methods, but their order changes in the PageRank results. Since their PageRank weights are very close, this difference should be interpreted as a minor variation rather than a substantial change in priority. Overall, the comparison suggests that the main prioritization pattern is stable, particularly for the upper-priority group, while the middle and lower groups require more context-sensitive interpretation.

Taken together, the comparative findings support the proposed framework as a structured tool for interpreting expert-based prioritization results. The convergence of C1, C3, C2, C5, and C4 across all methods provides a strong prioritization signal for early-stage ISO/IEC 27001 implementation planning. At the same

time, the rank changes observed for C8, C10, C11, C6, and C7 provide useful information for interpreting closely positioned items in light of organizational context, existing infrastructure, and implementation maturity.

5 Findings

The empirical results provide a stable expert-based prioritization pattern for the selected ISO/IEC 27001 implementation investment items. First, the leave-one-expert-out sensitivity analysis shows that the upper-priority group remains largely consistent across expert-exclusion scenarios. In particular, C1 (Server Room Setup), C3 (System Redundancy/Backup), and C2 (Disaster Recovery Center) consistently appear among the highest-priority items. The Spearman rank correlation coefficients between the baseline ranking and the leave-one-expert-out scenarios range from 0.9269 to 0.9977, indicating that the overall ranking structure is not driven by a single expert. This finding indicates a strong convergence among experts regarding foundational infrastructure, redundancy/backup, and disaster recovery capabilities in early-stage ISO/IEC 27001 implementation planning.

Second, the cross-method comparison shows a similar prioritization pattern across RANCOM, Copeland, and PageRank. C1, C3, C2, C5, and C4 retain the same first five positions across all three methods. This convergence suggests that the upper part of the ranking is not strongly dependent on a single aggregation logic. Therefore, the comparison of the three methods strengthens the interpretation of these items as a consistent upper-priority group.

Third, the middle and lower parts of the ranking display greater method-dependent variation. Items such as C8 (Email Hosting Architecture and Cloud-Service Governance), C10 (Domain Structure Migration), C11 (Competency Training), C9 (NAC System Setup), C7 (Awareness Training), and C6 (SoA Documentation) have relatively close scores and show some changes across methods or expert-exclusion scenarios. These results do not reduce the usefulness of the ranking; rather, they indicate that the ordering of these items should be interpreted together with organizational context, existing infrastructure, implementation maturity, and internal capability.

Overall, the findings suggest that the proposed expert-based comparative ranking framework is most informative for identifying the upper-priority implementation items, while also providing useful guidance for interpreting closely positioned items in the middle and lower parts of the ranking.

6 Conclusion

This study proposed an expert-based multi-criteria decision analysis framework for prioritizing selected ISO/IEC 27001 implementation investment items. The study focused on eleven practical implementation items, including ten major investment areas and the SoA, and evaluated them using judgments from ten information security and IT professionals. RANCOM was used as the primary expert-judgment aggregation method, while Copeland and PageRank were employed as comparative ranking approaches to examine the consistency of the resulting priority structure.

The main finding is that C1 (Server Room Setup), C3 (System Redundancy/Backup), and C2 (Disaster Recovery Center) consistently emerge as the highest-priority items across the analyses. In addition, C5 (Infrastructure Maintenance) and C4 (Card Access System) consistently retain the fourth and fifth positions across RANCOM, Copeland, and PageRank. These results indicate that experts tend to prioritize physical infrastructure, availability, recoverability, and access control capabilities during the early stages of ISO/IEC 27001 implementation planning.

From a managerial perspective, the findings provide practical decision-support evidence for organizations planning ISO/IEC 27001 implementation. The results suggest that early-stage planning should give particular attention to foundational infrastructure and continuity-related capabilities before moving toward more context-dependent implementation items. However, the prioritization should not be interpreted as a universal implementation sequence. Organization-specific risk assessments, existing infrastructure, regulatory requirements, budget limitations, and internal competencies should also be considered when translating the ranking results into implementation decisions. In practice, these conditions may also change over time and may therefore introduce additional uncertainty into implementation decisions. Accordingly, the present ordinal prioritization should be viewed as one input to managerial decision-making rather than as a substitute for organization-specific risk, budget, and regulatory assessments.

The study also shows that middle- and lower-ranked items require more contextual interpretation. For example, email hosting architecture, domain structure migration, competency training, NAC implementation, awareness training, and SoA documentation may vary in priority depending on organizational maturity, cloud adoption strategy, existing IT architecture, and audit readiness. Therefore, the proposed framework should be used as a structured decision-support tool rather than as a deterministic implementation prescription.

The relative importance of the implementation items may also vary across organizational settings. For example, SMEs may place greater emphasis on resource feasibility and

existing internal capabilities, whereas critical infrastructure operators may assign greater importance to continuity, redundancy, and resilience-related investments. In cloud-native organizations, cloud-service governance and identity-related capabilities may receive greater managerial attention, while highly regulated organizations may place relatively greater emphasis on compliance, documentation, and audit readiness. These context-specific differences are not estimated in the present study and should therefore be examined through organization- or sector-specific applications of the proposed framework.

The study has several limitations. First, the prioritization results are based on expert judgments rather than direct cost, risk reduction, or post-implementation performance data. Second, although the comparison of RANCOM, Copeland, and PageRank reduces dependence on a single aggregation logic, it does not eliminate model uncertainty. Third, possible dependencies among implementation items, such as the operational relationship between server room setup and supporting infrastructure services, are not explicitly modeled in the current framework. Organizational size, threat landscape, regulatory pressure, existing infrastructure, budget limitations, internal competencies, and cloud adoption strategy may influence how the ranking should be translated into practice.

Future research may extend the proposed framework in several ways. First, explicit dependencies among implementation items can be modeled using methods such as DEMATEL, ANP, or network-based causal approaches. Second, cost, implementation time, resource availability, threat conditions, organizational maturity, and regulatory requirements can be incorporated as additional decision dimensions or scenario-specific inputs. Third, uncertainty in expert judgments may be examined more explicitly through larger expert panels, alternative expert-weighting schemes, probabilistic preference distributions, Bayesian approaches, and fuzzy or interval-based extensions of RANCOM. Scenario-based and stochastic or game-theoretic approaches may also be considered when decision conditions and resource constraints are represented as uncertain or changing parameters [34]. Finally, the prioritization results can be validated through case studies, post-implementation performance indicators, audit findings, or organization-specific ISO/IEC 27001 implementation outcomes [35].

Appendix A

See Table 6.

Table 6 Anonymized professional profile of the expert panel

Expert	Professional role	Main expertise	ISO/IEC 27001/Information security experience	Education level
E1	System and network officer	Network and cybersecurity	2 years	Associate degree
E2	System certification manager	ISO standards and information security	15 years	Bachelor's degree; master's ongoing
E3	Engineer	Systems administration	12 years	Bachelor's degree
E4	Cybersecurity manager	Information security	7 years	University degree
E5	Senior engineer	Systems and cybersecurity	2 years	Master's degree
E6	ISMS manager/analyst	Software development and ISO/IEC 27001 ISMS	1 year	Bachelor's degree
E7	Branch manager	Information security and information systems	20 years	Master's degree
E8	Branch manager	Network and server systems	3 years	University degree
E9	Technician	Systems and network	3 years	Associate degree
E10	Department head	Information technologies	5 years	Master's degree

Supplementary Information The online version contains supplementary material available at https://doi.org/10.1007/s10207-026-01347-6.

Author contributions S.C. conceived and designed the study, performed the analyses, and wrote the main manuscript text. F.T. contributed to the methodology and data interpretation and assisted in manuscript writing and revision. S.C. is the corresponding author. All authors reviewed and approved the final manuscript.

Funding No funding was received for conducting this study.

Data availability All data analyzed in this study are included in the article and the supplementary information files.

Declarations

Conflict of interest The authors declare that they have no competing interests.

Declaration of AI and AI-assisted technologies in the writing process During the preparation of this work the authors used ChatGPT and Google Gemini in order to improve the language quality of the manuscript (e.g., grammar, clarity, and readability). After using these tools/services, the authors reviewed and edited the content as needed and take full responsibility for the content of the published article.

Open Access This article is licensed under a Creative Commons Attribution 4.0 International License, which permits use, sharing, adaptation, distribution and reproduction in any medium or format, as long as you give appropriate credit to the original author(s) and the source, provide a link to the Creative Commons licence, and indicate if changes were made. The images or other third party material in this article are included in the article's Creative Commons licence, unless indicated otherwise in a credit line to the material. If material is not included in the article's Creative Commons licence and your intended use is not permitted by statutory regulation or exceeds the permitted use, you will need to obtain permission directly from the copyright holder. To view a copy of this licence, visit http://creativecommons.org/licenses/by/4.0/.

References

1. Basuchoudhary, A., Searle, N.: Snatched secrets: cybercrime and trade secrets modelling a firm's decision to report a theft of trade secrets. Comput. Secur. **87**, 101591 (2019). https://doi.org/10.1016/j.cose.2019.101591
2. Antunes, M., Maximiano, M., Gomes, R., Pinto, D.: Information security and cybersecurity management: a case study with SMEs in Portugal. J. Cybersecur. Privacy **1**(2), 219–238 (2021). https://doi.org/10.3390/jcp1020012
3. Taherdoost, H.: Understanding cybersecurity frameworks and information security standards: a review and comprehensive overview. Electronics **11**(14), 2181 (2022). https://doi.org/10.3390/electronics11142181
4. Azmi, R., Tibben, W., Win, K.T.: Review of cybersecurity frameworks: context and shared concepts. J. Cyber Policy **3**(2), 258–283 (2018). https://doi.org/10.1080/23738871.2018.1520271
5. Šikman, L., Latinović, T., Paspalj, D.: ISO 27001—information systems security, development, trends, technical and economic challenges. Annals Faculty Eng. Hunedoara **17**(4), 45–48 (2019)
6. Maček, D., Magdalenić, I., Rađep, N.B.: A systematic literature review on the application of multicriteria decision making methods for information security risk assessment. Int. J. Saf. Secur. Eng. **10**(2), 161–174 (2020). https://doi.org/10.18280/ijsse.100202
7. Więckowski, J., Kizielewicz, B., Shekhovtsov, A., Sałabun, W.: RANCOM: a novel approach to identifying criteria relevance based on inaccuracy expert judgments. Eng. Appl. Artif. Intell. **122**, 106114 (2023). https://doi.org/10.1016/j.engappai.2023.106114
8. Więckowski, J., Wątróbski, J., Shkurina, A., Sałabun, W.: Adaptive multi-criteria decision making for electric vehicles: a hybrid approach based on RANCOM and ESP-SPOTIS. Artif. Intell. Rev. **57**, 270 (2024). https://doi.org/10.1007/s10462-024-10901-4
9. Więckowski, J., Wątróbski, J., Sałabun, W.: Inaccuracies in expert judgment: comparative analysis of RANCOM and AHP methods in housing location selection problem. IEEE Access **12**, 142083–142100 (2024). https://doi.org/10.1109/ACCESS.2024.3443451
10. Al-Sharrah, G.: Ranking using the Copeland score: a comparison with the Hasse diagram. J. Chem. Inf. Model. **50**(5), 785–791 (2010). https://doi.org/10.1021/ci100064q
11. Lestari, S., Adji, T.B., Permanasari, A.E.: Performance comparison of rank aggregation using Borda and Copeland in recommender system. In: 2018 International Workshop on Big Data and Information Security (IWBIS). pp. 69–74. IEEE (2018). https://doi.org/10.1109/IWBIS.2018.8471722
12. Altman, A., Tennenholtz, M.: Ranking systems: The PageRank axioms. In: Proceedings of the 6th ACM Conference on Electronic Commerce. pp. 1–8. ACM (2005). https://doi.org/10.1145/1064009.1064010
13. Ding, Y., Yan, E., Frazho, A., Caverlee, J.: PageRank for ranking authors in co-citation networks. J. Am. Soc. Inf. Sci. Technol. **60**(11), 2229–2243 (2009). https://doi.org/10.1002/asi.21171
14. International Organization for Standardization: ISO/IEC 27001: What's new in IT security? ISO, Geneva (2022). https://www.iso.org/contents/news/2022/10/new-iso-iec-27001.html. Accessed 13 Jan 2026
15. Kosutic, D.: ISO 27001 2013 versus 2022 revision—What has changed? Advisera (2022). https://advisera.com/27001academy/blog/2022/02/09/iso-27001-iso-27002/. Accessed 13 Jan 2026
16. International Organization for Standardization: International Electrotechnical Commission: ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection: Information security management systems—Requirements. ISO/IEC, Geneva (2022)
17. NSF: ISO/IEC 27001 information security management system. https://www.nsf.org/management-systems/iso-iec-27001. Accessed 13 Jan 2026
18. Mera-Amores, F., Roa, H.N.: Enhancing Information Security Management in Small and Medium Enterprises (SMEs) through ISO 27001 compliance. In: Arai, K. (ed.) Advances in Information and Communication. FICC 2024. Lecture Notes in Networks and Systems, vol. 920. Springer, Cham (2024). https://doi.org/10.1007/978-3-031-53963-3_14
19. Ali, A.B.A., Ayyasamy, R.K., Akbar, R., Jebna, A.K., Adnan, K.: Cybersecurity infrastructure compliance key factors to detect and mitigate malware attacks in SMEs: a systematic literature review. SAGE Open **15**(1), 1–19 (2025). https://doi.org/10.1177/21582440251346
20. Nikbakht, M., Rouhani, S., Mojtahed, V.: A novel ranking model for information technology security controls through COBIT and MCDM. Rec. Manag. J. **3**(35), 251–276 (2025). https://doi.org/10.1108/RMJ-03-2024-0007
21. Daghouri, A., Mansouri, K.: Hierarchical models of information systems security metrics: a comparative sectoral approach. Eng. Technol. Appl. Sci. Res. **14**(6), 17761–17768 (2024). https://doi.org/10.48084/etasr.8401
22. Khan, R.A., et al.: A Fuzzy-AHP decision-making framework for optimizing software maintenance and deployment in information

security systems. Journal of Software: Evolution and Process **37**(1), (2025). https://doi.org/10.1002/smr.2758
23. Barlybayev, A., Turginbayeva, A.: Development and implementation of an advanced fuzzy expert system for the assessment of information security risks. J. Comput. Cogn. Eng. (2025). https://doi.org/10.47852/bonviewJCCE52024683
24. Tariq, M.I., et al.: Prioritization of information security controls through Fuzzy AHP for cloud computing networks and wireless sensor networks. Sensors **20**(5), 1310 (2020). https://doi.org/10.3390/s20051310
25. Turskis, Z., Goranin, N., Nurusheva, A., Boranbayev, S.: Information security risk assessment in critical infrastructure: a hybrid MCDM approach. Informatica **30**(1), 187–211 (2019). https://doi.org/10.15388/Informatica.2019.203
26. Nasser, A.A., et al.: Measuring the information security maturity of enterprises under uncertainty using Fuzzy AHP. Int. J. Inf. Technol. Comput. Sci. **10**(4), 10–25 (2018). https://doi.org/10.5815/ijitcs.2018.04.02
27. Muntaha, M.S., et al.: Analyzing the relevance of inhibiting factors in implementing ISO 27001 using the DEMATEL method. In: 2019 5th International Conference on Computing Engineering and Design (ICCED). IEEE (2019). https://doi.org/10.1109/ICCED46541.2019.9161084
28. Ramalingam, D., et al.: A novel approach for optimizing governance, risk management and compliance for enterprise information security using DEMATEL and FoM. Procedia Comput. Sci. **134**, 365–370 (2018). https://doi.org/10.1016/j.procs.2018.07.197
29. Fielder, A., Panaousis, E., Malacaria, P., Hankin, C., Smeraldi, F.: Decision support approaches for cyber security investment. Decis. Support. Syst. **86**, 13–23 (2016). https://doi.org/10.1016/j.dss.2016.02.012
30. Zhang, Y., Malacaria, P.: Bayesian Stackelberg games for cybersecurity decision support. Decis. Support. Syst. **148**, 113599 (2021). https://doi.org/10.1016/j.dss.2021.113599
31. Zhang, Y., Malacaria, P.: Keep spending: Beyond optimal cybersecurity investment. In: 2023 IEEE 36th Computer Security Foundations Symposium (CSF). IEEE (2023). https://doi.org/10.1109/CSF57540.2023.00024
32. Barraza de la Paz, J.V., et al.: Análisis del control técnico "8.1 usuarios de punto final" de la ISO/IEC 27001:2022 utilizando FTA y MCDM. Abstraction & Application 42, 13–28 (2023)
33. Więckowski, J., Kizielewicz, B., Sałabun, W.: Fuzzy RANCOM: a novel approach for modeling uncertainty in decision-making processes. Inf. Sci. **694**, 121716 (2025). https://doi.org/10.1016/j.ins.2024.121716
34. Zarei, E., Yazdi, M., Moradi, R., BahooToroody, A.: Expert judgment and uncertainty in sociotechnical systems analysis. In: Zarei, E. (ed.) Safety Causation Analysis in Sociotechnical Systems: Advanced Models and Techniques, vol. vol. 541, pp. 487–530. Springer, Cham (2024). https://doi.org/10.1007/978-3-031-62470-4_18
35. Li, H., Yazdi, M.: Stochastic game theory approach to solve system safety and reliability decision-making problem under uncertainty. In: Li, H., Yazdi, M. (eds.) Advanced Decision-Making Methods and Applications in System Safety and Reliability Problems: Approaches, Case Studies, Multi-Criteria Decision-Making, Multi-Objective Decision-Making, Fuzzy Risk-Based Models, pp. 127–151. Springer, Cham (2022). https://doi.org/10.1007/978-3-031-07430-1_8

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.